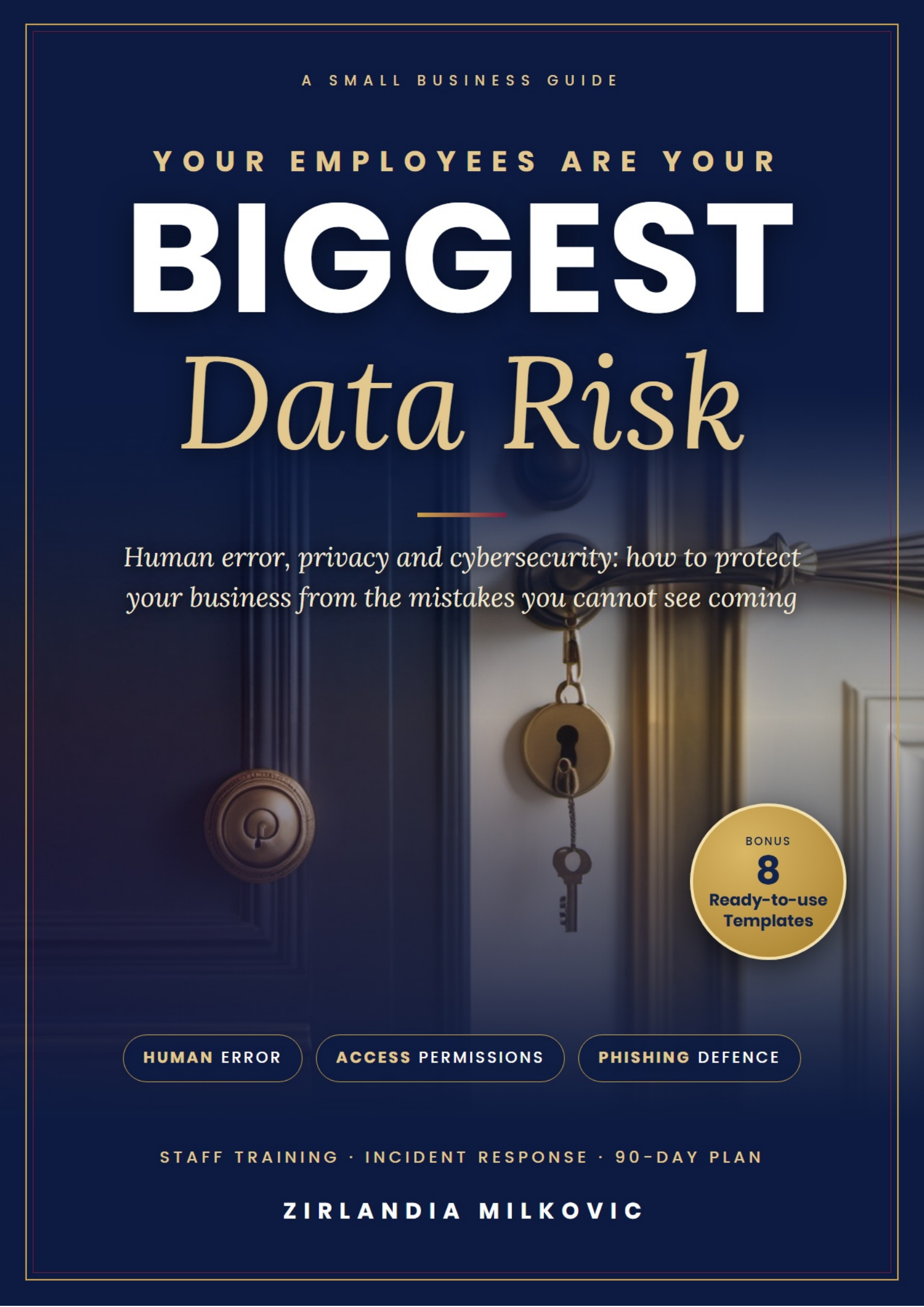
A SMALL BUSINESS GUIDE

YOUR EMPLOYEES ARE YOUR BIGGEST *Data Risk*

Human error, privacy and cybersecurity: how to protect your business from the mistakes you cannot see coming



BONUS
8
Ready-to-use Templates

HUMAN ERROR | **ACCESS** PERMISSIONS | **PHISHING** DEFENCE

STAFF TRAINING · INCIDENT RESPONSE · 90-DAY PLAN

ZIRLANDIA MILKOVIC



YOUR EMPLOYEES ARE YOUR BIGGEST *Data* RISK

A Small Business Guide to Human Error, Privacy and Cybersecurity

ZIRLANDIA MILKOVIC

FOR SMALL BUSINESSES · PRIVACY · CYBERSECURITY

Your Employees Are Your Biggest Data Risk

A Small Business Guide to Human Error, Privacy and Cybersecurity

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for printing the worksheets, checklists and the policy template for your own business use.

NOT LEGAL ADVICE. This book is an educational guide to the EU General Data Protection Regulation (Regulation (EU) 2016/679). It is not legal advice, does not create a lawyer-client or consultant-client relationship, and does not take your individual circumstances into account. Reading it, following it or using its templates does not make a business GDPR compliant and is not a certification or a guarantee of compliance.

LAWS CHANGE. Data protection law, regulatory guidance, court decisions and national rules develop continuously. The book reflects the author's understanding as of its publication date (2026) and refers to official sources so that you can check what applies now. National laws, supervisory-authority guidance and sector rules differ between countries. Before you rely on anything here for a decision with real consequences, take advice from a qualified lawyer or data protection professional in the relevant country.

Product and company names (for example email, analytics, advertising and AI platforms) are the property of their respective owners and are used only as examples for identification and education. This independent book is not affiliated with, sponsored by or endorsed by any of them, and no product is recommended or certified as compliant.

Every person, business and incident described in the case studies and scenarios is fictional and was created to illustrate ideas. Any resemblance to real people or companies is coincidental.

Premium Edition 2026 · PDF with clickable contents, bookmarks and fillable worksheets

Contents

Note	A Note from the Author	5
01	The Human Factor	6
02	Accidental Data Exposure	10
03	What the GDPR Expects	15
04	Employee Access Permissions	20
05	Phishing and Social Engineering	26
06	Remote Work, Devices and Shadow IT	31
07	Staff Privacy Training That Works	36
08	Policies Your Team Will Actually Follow	42
09	When It Goes Wrong	46
10	Your 90-Day Human Risk Plan	51
Bonus	The Staff Protection Toolkit	57
A–Z	Plain-English Glossary	66
Ref	Official Sources & Further Reading	67
Bio	About the Author	68

A Note from the Author

Why the biggest hole in your security is not a piece of software.

Most small businesses I speak to have done something about cybersecurity. There is an antivirus on the laptops, a firewall somewhere, and a password on the Wi-Fi. Then I ask a different question: "*What happens when someone on your team clicks the wrong link, emails the wrong customer, or leaves and takes their login with them?*" The room goes quiet.

Technology rarely fails first. **People do**, and almost never on purpose. A tired colleague replies to a convincing email. A well-meaning manager shares a folder with "anyone with the link". A new starter is given the same access as the owner because it was quicker. None of them is a villain. All of them are the reason customer data ends up where it should not be.

The good news is that the human factor is the most fixable risk you have. You cannot patch a person, but you can **design the work so that mistakes are harder to make, easier to spot and cheaper to survive**. That is what this guide is about: four practical areas (accidental exposure, access permissions, phishing and social engineering, and staff training), explained in plain English for businesses with no IT department and no budget for one.

This book is not about blaming your team. It is about giving them clear rules, the right access, and the confidence to say "*I think I made a mistake*" in the first hour rather than the third week. At the back you will find a ready-to-adapt **Staff Data Protection Rules** page, an incident report form, an access review grid and a training log.

> AI & PRIVACY **How to use this book**
>
> Chapters 1 to 3 explain the risk and what the GDPR expects. Chapters 4 to 6 cover access, phishing and everyday working habits. Chapters 7 to 10 show how to train, write rules people follow, respond to incidents and build a 90-day plan. **Numbers, timelines and tools are starting points, not legal rules.** Always check what applies to your country, sector and size.

PART I · THE HUMAN RISK

CHAPTER

01

The Human Factor

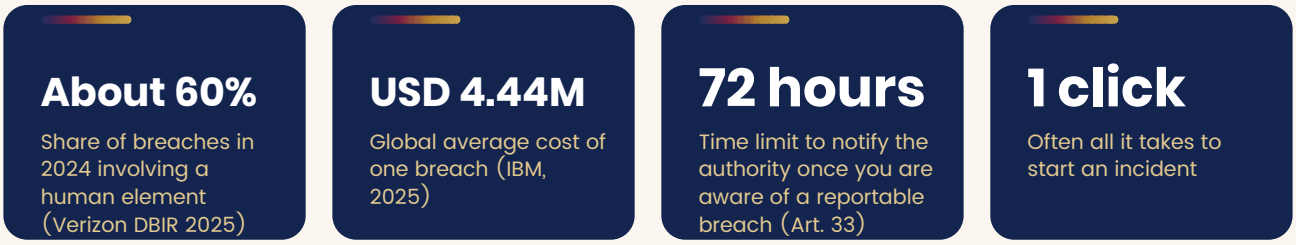
Why the people on your payroll cause more data incidents than any hacker, and why that is good news.

IN THIS CHAPTER

- Why employees sit at the centre of most data incidents
- The four kinds of insider risk, and which one is most common
- Why blaming people makes the problem worse
- What a mistake can cost a small business

Picture a business of twelve people: a small agency, an online shop, an accountancy practice. Nobody there is careless by nature. Yet in an ordinary week, someone will forward a spreadsheet to a personal email "to finish at home", someone will use the same password they use for their streaming account, someone will click a link in an email that looked like it came from the courier, and someone will leave a client folder open to the whole company because nobody told them not to.

Each of those moments is tiny. Together they are how real data breaches happen. Large industry studies keep reaching the same conclusion year after year: **the human element is involved in a majority of breaches**, through stolen or reused credentials, deception, honest mistakes and misuse of access.



The human risk in four numbers

> AI & PRIVACY **About these figures**
>
> Statistics change every year. The numbers above come from the Verizon *Data Breach Investigations Report* 2025 and IBM's *Cost of a Data Breach Report* 2025. Averages are driven by large organisations: a small business will usually pay less in absolute terms, but proportionally more, because it has fewer reserves and no specialist team. Check the latest edition before quoting them.

Four kinds of insider risk

Security people use the word **insider** for anyone who already has legitimate access: employees, freelancers, interns, contractors and agency staff. Not all insider risk looks the same, and the fixes differ.

THE CARELESS

Knows the rule, skips it under pressure. Sends data to a personal account, uses a weak password, leaves a screen unlocked. By far the most common source of incidents.

THE DECEIVED

Follows the rule, but is tricked. Replies to a fake invoice, approves a login request that was not theirs, hands a code to a "colleague" on the phone.

THE CURIOUS

Looks at records they have no reason to see: a celebrity customer, a neighbour, an ex-partner. Almost always because access was wider than needed.

THE MALICIOUS

Deliberately steals, sells or destroys data, often when leaving or after a dispute. Rare, but the most expensive per incident.

Figure 1 The four faces of insider risk

Notice that three of the four are not about bad intent at all. They are about **access, training and pressure**. That is why this book spends more time on permissions, habits and culture than on software.

Why blame backfires

When a mistake happens, the instinct is to find who did it. That feels like accountability. In practice it teaches the whole team one lesson: *hide it*. A colleague who sent a file to the wrong person on Monday and says nothing until a customer complains on Friday has just turned a one-hour problem into a five-day one, and used up most of the time you have to notify the authority.

AI & PRIVACY **The no-blame rule**

People report quickly in workplaces where reporting is safe. The goal of an incident review is to find out **what made the mistake easy**, not who made it. Deliberate misuse is dealt with separately, and that is the exception.

What an everyday mistake can cost

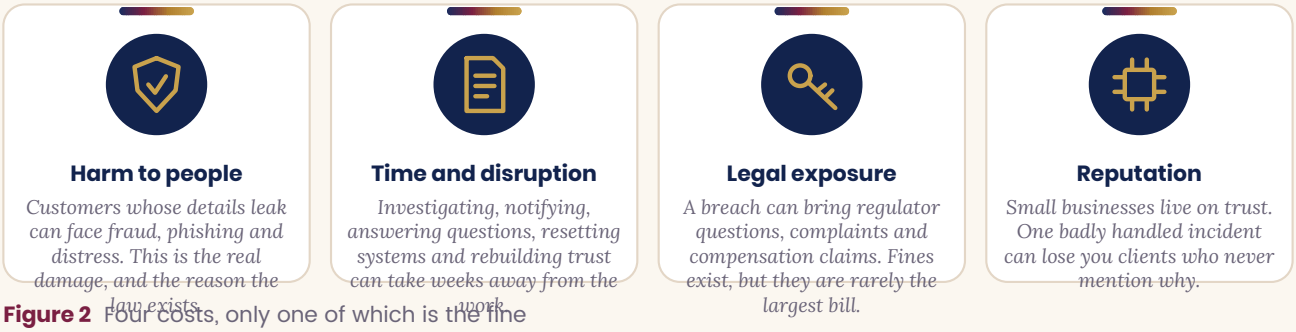


Figure 2 Four costs, only one of which is the fine

REAL-WORLD SCENARIO **Real-world scenario: the helpful email**

A fictional ten-person recruitment firm sends a weekly update to 300 candidates. A junior colleague, new and keen to help, pastes all the addresses into the "To" field instead of "BCC". Every candidate now sees every other candidate's name and email, and several are currently employed by competitors of the firm's clients. There was no malice, no hacker and no software failure. There was a missing procedure, a missing safeguard in the email tool, and a person on their second week.

Where the risk actually lives

You do not need to fix everything at once. Most small-business incidents come from a short list of places. If you cover these, you cover most of the risk.



Figure 3 The four-link human security chain

DO THIS NOW **Do this now (10 minutes)**

Write down the last three data mistakes you know of in your business, however small: a wrong attachment, a lost phone, a shared password. For each, answer one question: *what would have made this harder to do?* You have just started your risk register.

PART I · THE HUMAN RISK

CHAPTER

02

Accidental Data Exposure

The everyday slips that put personal data in the wrong hands, and the simple guardrails that stop them.

IN THIS CHAPTER

- The eight most common ways staff expose data by accident
- Why the wrong-recipient email is the classic GDPR breach
- Small settings that remove whole categories of mistakes
- When an accident becomes a reportable breach

Under the GDPR a **personal data breach** is not only a hack. It is any breach of security that leads to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (Article 4(12)). An email sent to the wrong person is a breach. A lost laptop is a breach. A shared link that anyone can open is a breach waiting to be found.

That definition is helpful because it tells you where to look. Most accidental exposure falls into three buckets: **disclosure** (the wrong person sees it), **loss** (you can no longer find it or control it) and **alteration or destruction** (someone changes or deletes it by mistake).

The eight classic slips

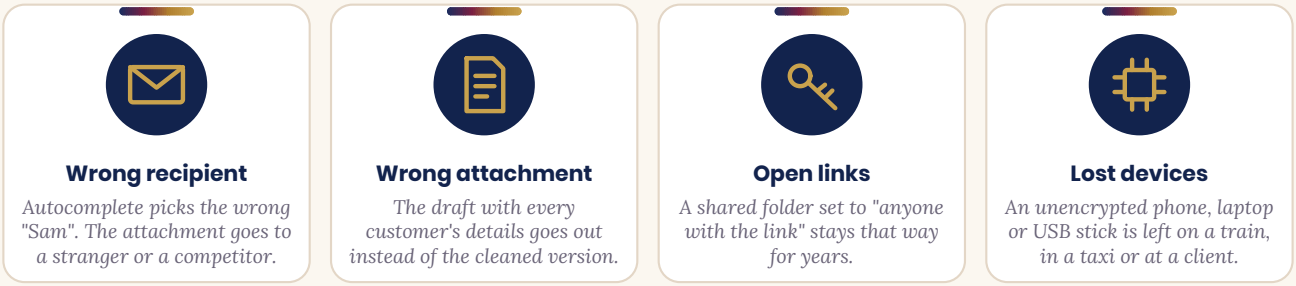


Figure 4 Where accidents usually start



Figure 5 And four more

Email: the number one source

Email is how small businesses share almost everything, and it was never designed for confidentiality. It does not warn you when you are about to send something sensitive to the wrong person. Your tools can, if you switch the right features on.

BEFORE & AFTER **Sending a file with personal data**

RISKY	*Attach the spreadsheet and send it to whoever is in the autocomplete list.*
BETTER	*Check the recipient's full address, remove columns the recipient does not need, and send.*
BEST PRACTICE	*Share through a secure link with an expiry date and a named recipient, protect the file with a password sent by another channel, and switch on your mail system's "are you sure you want to send this outside the company?" warning.*
WHY IT MATTERS	Each extra step is a point where a mistake can be caught. The strongest option removes the attachment entirely, so a wrong send can be withdrawn.

FOUNDER TIP **Founder Tip: five settings that prevent most email accidents**

1. Turn off autocomplete for external addresses, or add a short delay before sending (most business email tools offer an "undo send" window of 10 to 30 seconds). 2. Add a warning banner for emails going to outside domains. 3. Block automatic forwarding to personal accounts. 4. Use a mailing tool, not CC or BCC, for group messages. 5. Mark external senders clearly so impersonation stands out.

Sharing links and cloud drives

Cloud storage solved the problem of version chaos and created a new one: invisible exposure. A link that was shared "just for this meeting" can stay live forever, be forwarded to anyone, and appear in search results inside a company account. The fix is to change the default.

RISKY: SHARING BY CONVENIENCE

- Default sharing is "anyone with the link".
- Links never expire.
- Former colleagues and freelancers keep access.
- Nobody knows what has been shared externally.

BETTER: SHARING BY DESIGN

- Default sharing is "specific people" only.
- Links to sensitive folders expire after days or weeks.
- Access is reviewed every quarter and at every exit.
- A monthly report lists every externally shared item.

Figure 6 Two ways to run a shared drive

Devices, paper and the world outside

Phones, laptops and USB sticks leave the building every day. The question is not *if* one will be lost, but whether the loss becomes a breach. **Encryption** is the difference. A lost, encrypted and locked laptop usually exposes nothing, and regulators generally treat the risk very differently from a lost, unencrypted one.

DEVICE SAFEGUARDS

- [ ] Full-disk encryption is switched on for every laptop and phone that touches business data.
- [ ] Screen lock is enforced after a short idle time and needs a PIN, password or biometric.
- [ ] Lost or stolen devices can be located, locked and wiped remotely.
- [ ] USB sticks and external drives are not used for personal data, or are encrypted and logged.
- [ ] Staff know who to call, and how fast, if a device goes missing.
- [ ] Paper with personal data is locked away, and shredded when no longer needed.

Public AI tools: the new leak

One of the fastest-growing sources of accidental exposure is the well-meaning employee who pastes a customer complaint, a contract or a spreadsheet into a public AI chatbot "to summarise it". Depending on the service and settings, that data may leave your control, be stored, or be used to improve the service. The fix is a clear rule on which tools are approved, which data may never be entered, and an approved alternative so staff are not tempted to improvise.

> WATCH OUT **Watch out**
>
> "We did not know" is not a defence you want to rely on. Staff will use the fastest tool available. Give them a safe one, and write down what must never be pasted into any tool: health data, ID documents, payment details, passwords, and anything you promised a client to keep confidential.

When does an accident become a reportable breach?

Not every slip must be reported to the authority, but **every breach must be recorded** (Article 33(5)). The test for reporting is risk to the people affected. If the breach is *unlikely to result in a risk* to their rights and freedoms, you need only document it. If there is a risk, you notify the supervisory authority **without undue delay and, where feasible, within 72 hours** of becoming aware. If the risk is *high*, you must also tell the individuals affected, without undue delay (Article 34).

1	**Did personal data get lost, disclosed, altered or accessed without authority?**	**YES** Continue to question 2	**NO** It is not a personal data breach. Note it as a near miss and fix the cause.
2	**Is it unlikely to result in any risk to the people involved (for example, the data was encrypted, or went to a trusted recipient who deleted it)?**	**YES** Record it in your breach log with your reasoning, and stop here	**NO** Continue to question 3
3	**Could it cause risk, such as embarrassment, loss of control, fraud or discrimination?**	**YES** Notify the supervisory authority within 72 hours of becoming aware	**NO** Continue to question 4
4	**Is the risk high, for example sensitive data, financial data, large numbers or vulnerable people?**	**YES** Also tell the individuals affected, in clear language, without undue delay	**NO** Record, review and fix the cause

Figure 7 Is this accident a reportable breach?

WHAT GDPR REQUIRES **What GDPR requires**

Security is not optional. Article 5(1)(f) requires personal data to be processed in a way that ensures appropriate security, including protection against accidental loss, destruction or damage. Article 32 requires "appropriate technical and organisational measures", and organisational measures include the rules, training and habits in this book.

DO THIS NOW **Do this now (20 minutes)**

Open your shared drive and search for items shared "with anyone who has the link". Change the three most sensitive to named people only. Then check your email system for an "undo send" setting and switch it on.

PART I · THE HUMAN RISK

CHAPTER

03

What the GDPR Expects

The Articles that make staff behaviour your legal responsibility, and what "appropriate measures" means for a small team.

IN THIS CHAPTER

- Why you are responsible for what your employees do with personal data
- The handful of Articles that matter for people-related risk
- What regulators mean by "technical and organisational measures"
- How the size of your business changes what is expected

You do not need to read all 99 Articles of the GDPR to manage human risk. A small handful do the work. Understanding them changes how you think about staff mistakes: they are not just an HR problem or an IT problem, they are **your legal responsibility as the controller**.

You are responsible for your people

Under the GDPR the business decides why and how personal data is used, which makes it the **controller**. Employees acting on your instructions are not separate controllers. When a member of staff makes a mistake with customer data while doing their job, the responsibility generally sits with the business. This is why training, clear rules and sensible access are not optional extras: they are how you show you took responsibility.



Figure 8 The GDPR Articles that matter for human risk

The Articles in plain English

What each Article asks of a small business

Article	In plain English	What it means for staff risk
5(1)(f)	Keep data secure, including against accidental loss or damage	Guard against mistakes, not only attacks
5(2) and 24	Be able to show that you comply, with measures that fit your risks	Write rules down, train people, keep records
25	Build privacy in by default	Limit access and sharing from the start
28	Contractors handling data for you need a contract and must be careful	Freelancers and agencies are part of your risk
29 and 32(4)	People working for you act only on your instructions	Staff need instructions: a policy, not guesses
32	Apply measures suited to the risk: encryption, resilience, testing	Access control, MFA, backups, training
33	Report reportable breaches to the authority within 72 hours	Staff must know how to raise the alarm
34	Tell individuals when risk is high	Prepare a template message in advance

What "appropriate" means for a small business

Article 32 does not say "buy this product". It asks you to take into account the state of the art, the cost, the nature and scope of what you do, and the risks to the people involved. In practice this means **proportionate**: a two-person design studio is not expected to run a security operations centre, but it is expected to use multi-factor authentication, keep software updated, restrict access and tell its staff what to do.

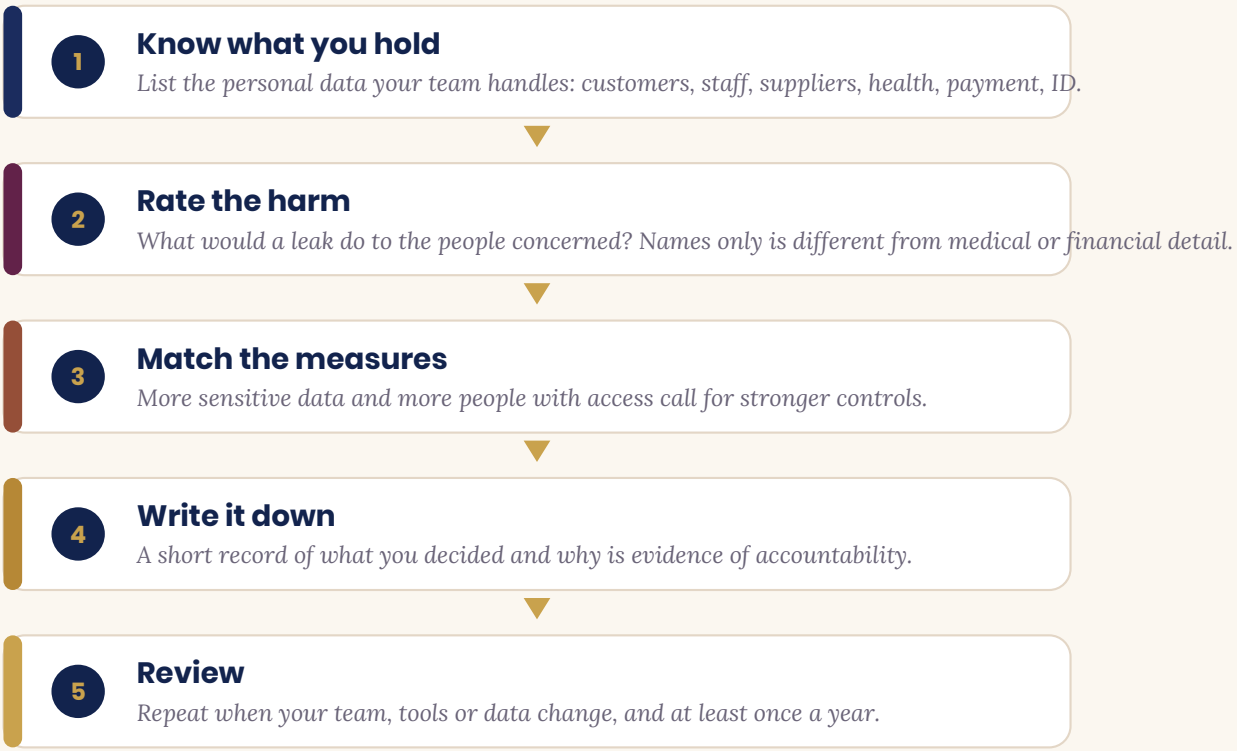


Figure 9 How to decide what is appropriate

WHAT GDPR REQUIRES **What GDPR requires**

Staff awareness is part of the legal picture. Article 39(1)(b) lists "awareness-raising and training of staff involved in processing operations" as a task of the Data Protection Officer, which shows how regulators see training: a normal and expected part of compliance. Even if you do not need a DPO, you still need to be able to show that someone is looking after this.

What happens when it goes wrong

Supervisory authorities look at the whole picture when something happens: what data was involved, how many people, whether the cause was a basic missing safeguard, and how the business reacted. Failing to apply appropriate security, or failing to notify, can lead to the **lower tier of fines**, up to **EUR 10 million or 2% of worldwide annual turnover**, whichever is higher (Article 83(4)). Breaches of the basic principles, such as the security principle, can fall into the higher tier of **EUR 20 million or 4%** (Article 83(5)). Authorities must consider the circumstances, and for small businesses the usual first steps are reprimands, orders and guidance rather than the maximum fine, but you should not plan on leniency.



What regulators weigh

GOOD PRACTICE **Good practice: what a regulator likes to see**

A short written staff policy. A training record with dates. An access list that someone reviews. A breach log that shows you recorded even small incidents. A named person who owns security. None of these requires expensive tools, and together they tell a clear story: *this business takes care.*

Individuals can claim too

Anyone who has suffered material or non-material damage because of a GDPR infringement has the right to claim compensation from the controller or processor (Article 82). Courts in Europe have made clear that non-material damage, such as distress or loss of control over data, can qualify, though the person must show actual damage and a causal link. For a small business this means a careless leak is not only a regulatory risk but a civil one.

If you are in scope of other rules

The GDPR is not the only framework that mentions people and security. Depending on your sector and size, the **NIS2 Directive** (for certain medium and large organisations in listed sectors), payment-card rules (PCI DSS), your insurance policy and your customers' own contracts may require specific measures such as staff training, multi-factor authentication or incident reporting. Many small businesses are outside NIS2, but if you supply larger clients, they may pass their requirements down to you.

WATCH OUT **Check, do not assume**

Ask your insurer what they require for cyber cover, and read the security clauses in your biggest client contracts. Policies often demand multi-factor authentication or staff training and can refuse a claim if you did not meet them.

PART II · ACCESS AND ATTACK

CHAPTER

04

Employee Access Permissions

Who can see what, why, and for how long: the single most effective control against both accidents and misuse.

IN THIS CHAPTER

- The principle of least privilege, in plain English
- A simple role-based access model for a small team
- The joiner, mover and leaver routine
- Shared accounts, admin rights and multi-factor authentication

If you could only fix one thing in this book, fix access. Every other risk gets smaller when fewer people can reach less data. A phished employee can only leak what their account can open. A curious employee can only look at what is visible to them. A leaver can only take what they still have access to.

Least privilege: the idea in one line

THE LEAST PRIVILEGE RULE

Give each person the minimum access they need to do their job, for as long as they need it, and no more.

It sounds obvious, yet in small businesses it is rare. Access grows by accident. Someone asks for a folder "just for a day". A manager is given admin rights during a crisis. A freelancer is added to the whole drive because it was quicker than choosing the right folder. Nobody removes anything, because nobody is responsible for removing anything.

Why small teams over-share

"IT'S FASTER"
Giving full access takes seconds. Choosing the right folders takes minutes. Under deadline pressure, speed wins.

"WE TRUST EVERYONE"
Trust is good, but it is not a security control. Trusted people make mistakes and get phished too.

"NOBODY OWNS IT"
Without a named owner, access is added and never reviewed, and former staff keep accounts for years.

"WE ARE TOO SMALL"
Small teams are targeted precisely because they have weaker controls and the same valuable data.

Figure 10 Four reasons access grows out of control

A simple role-based model

You do not need a complex identity system. Start with **roles**. List the five or six types of job in your business, list the systems and data each really needs, and give access to the role, not to the person. When someone moves, change the role, and the access follows.

Example access matrix for a ten-person online business

Role	Shop admin	Customer data	Finance	HR files	Marketing tools
Owner	Full	Full	Full	Full	Full
Operations	Orders only	Orders and addresses	None	None	None
Customer support	Read orders	Contact details	None	None	None
Finance (outsourced)	None	Invoice data only	Full	Payroll only	None
Marketing	None	Consented lists only	None	None	Full
Freelancer	None	None	None	None	Own campaign only

FOUNDER TIP **Founder Tip: start from "none"**

Create the matrix with every cell empty, then add access only where someone can say what job it supports. It is much easier to grant on request than to hunt for what to remove later.

Joiners, movers and leavers

Most access problems appear at three moments in a person's time with you. A short routine for each is worth more than any software.

Stage 1 — **Joiner**
Create accounts by role. Provide the staff rules. Complete training before access to sensitive data. Record what was granted.

Stage 2 — **Mover**
When duties change, add the new access and remove the old at the same time. Do not collect permissions.

Stage 3 — **Leaver**
Disable accounts on the last day (or earlier if risk requires). Recover devices. Change shared passwords. Redirect email.

Stage 4 — **After they leave**
Check that no access remains: cloud apps, social accounts, payment tools, shared mailboxes, personal devices.

Figure 11 The access lifecycle



Figure 12 The leaver routine

WATCH OUT **The forgotten account**

The most dangerous access is the one nobody remembers: a former freelancer's login to the CRM, a shared mailbox password the whole team knows, a personal email address used as the owner of a business account. Search your tools for users you do not recognise and accounts that have not been used in 90 days.

Shared accounts and admin rights

A shared login such as "info@" or a single password to the shop dashboard means you cannot tell who did what, and you cannot remove one person without changing it for everyone. Wherever possible, give each person their own account. Where a shared mailbox is unavoidable, use the system's built-in delegated access rather than a shared password.

RISKY: EVERYONE IS AN ADMIN

- Every manager can install software and change settings.
- Admin accounts are used for daily email and browsing.
- Nobody can say who changed the settings last.

BETTER: FEW ADMINS, USED RARELY

- Two named administrators, one as backup.
- Admins use a separate everyday account for normal work.
- Admin actions are logged and reviewed monthly.

Figure 13 Admin rights

Multi-factor authentication: the biggest win per hour spent

Passwords alone are weak: they are reused, guessed, leaked and phished. **Multi-factor authentication (MFA)** adds a second proof, such as an app prompt, a hardware key or a code. It will not stop every attack, but it blocks the large majority of automated account takeovers. Turn it on first for email, then for finance, the shop admin, the cloud drive and anything with customer data.

SMS CODES
Better than nothing, but vulnerable to SIM-swapping and interception. Use only if nothing else is available.

AUTHENTICATOR APP
A solid default. Codes live on the phone and change every 30 seconds. Watch for fake prompts.

SECURITY KEYS
The strongest option. A physical key is much harder to phish. Ideal for owners, admins and finance.

Figure 14 Choosing an MFA method

WATCH OUT **Watch out for prompt bombing**

Some attackers spam a victim with approval requests until they tap "approve" out of annoyance or confusion. Teach staff: an approval prompt you did not trigger is an attack. Deny it, then report it. Where possible use number-matching prompts that require typing a code shown on the login screen.

Passwords people can live with

Long beats complex. A **password manager** lets every person use unique, long, random passwords without remembering them, and makes sharing a credential safe and traceable. Ban reuse of work passwords elsewhere, and do not force frequent changes without reason; change them when there is evidence of compromise.

Review: the quarterly access check

Once a quarter, sit down for thirty minutes with the access matrix. Ask each system owner to confirm the list of users. Remove anyone who left, change anyone who moved, and ask why for anything unexplained. Record the date. This is one of the strongest pieces of evidence you can show a regulator or insurer.

ACCESS REVIEW CHECKLIST

- [ ] Every person has their own account in each business tool.
- [ ] The access matrix exists and was updated this quarter.
- [ ] Leavers are disabled on their last day, and the date is recorded.
- [ ] Admin rights belong to no more than two or three named people.
- [ ] MFA is on for email, finance, the shop or CRM and the cloud drive.
- [ ] Unused accounts older than 90 days have been reviewed.
- [ ] Freelancers and agencies have time-limited, role-limited access.
- [ ] A password manager is provided and used.

DO THIS NOW **Do this now (30 minutes)**

Pick your most important system (probably email or your shop). Export or list its users. Cross out everyone who left or no longer needs access. Switch on MFA for the admin account. You have just closed the most common door.

PART II · ACCESS AND ATTACK

CHAPTER

05

Phishing and Social Engineering

How attackers go through your people instead of your systems, and the habits that stop them.

IN THIS CHAPTER

- The main types of phishing and social engineering, and how they differ
- Seven warning signs that apply to almost every scam
- The pause-and-verify routine for money and data requests
- What two famous incidents teach a ten-person business

Social engineering means manipulating a person into giving away access, money or information. It works because it targets human nature: our wish to help, to obey authority, to avoid trouble and to act quickly. A firewall cannot recognise a friendly voice on the phone. Training and procedure can.

Phishing is the best-known form: a message that pretends to be someone you trust in order to make you click, log in, pay or reveal something. In Verizon's 2025 report, phishing and pretexting were the leading techniques in social-engineering incidents, and IBM's 2025 study found phishing to be the most common way into the organisations it examined. Attackers do not need to be clever when the basic trick still works.

The family of attacks

Common types of social engineering

Type	Channel	How it works
Phishing	Email	Mass message with a fake link or attachment: courier, bank, shared document, invoice
Spear phishing	Email	Tailored to one person using public information from LinkedIn, your website or earlier leaks
Smishing	SMS and chat	A short text with a link: parcel fees, bank alerts, "is this you in the photo?"
Vishing	Phone	A caller pretends to be IT, a bank or a supplier and asks for codes or remote access
Business email compromise	Email	Fake or hijacked mail from the boss or a supplier asking for an urgent payment or changed bank details
Pretexting	Any	An invented story, such as a new colleague, an auditor or a customer, to extract information step by step
MFA fatigue	App	Repeated login prompts until the victim approves one
QR phishing	Print and email	A QR code that hides a malicious address, placed in emails, posters or parcels

Two stories worth knowing

REAL-WORLD SCENARIO **Twitter, 2020: the phone call that opened the door**

In July 2020 attackers took over high-profile Twitter accounts. The company later explained that the attack began with a **phone spear-phishing campaign** aimed at a small number of employees, which gave the attackers a foothold and let them learn internal processes before targeting staff who did have access to account-support tools. Lesson: the first person tricked was not the most senior. A hundred small footholds are enough if access is broad.

REAL-WORLD SCENARIO **Uber, 2022: approve, approve, approve**

In September 2022 an attacker obtained a contractor's credentials and then bombarded the contractor with multi-factor approval requests. They also contacted the contractor, posing as IT, and told them accepting a request would stop the notifications. The contractor accepted, and the attacker was in. Lesson: MFA helps enormously, but only when people know that an unexpected prompt is an attack and when contractors are covered by the same training and rules as employees.

Seven warning signs



Figure 15 Signs that apply to nearly every scam

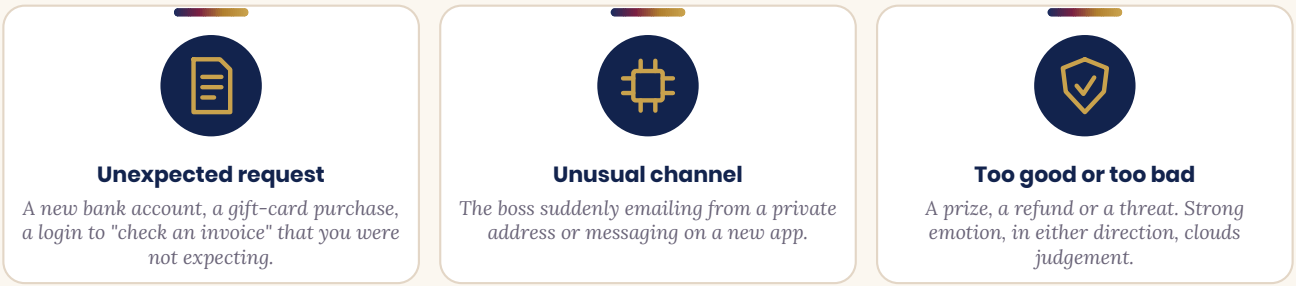


Figure 16 And three more

The pause-and-verify routine

You will never train everyone to spot every fake. The safer approach is to build a **routine for high-risk requests** that works even when the fake is perfect. The rule is simple: *any request involving money, credentials, personal data or a change of bank details is verified through a second, known channel before action.*



Figure 17 The verify-before-you-act routine

FOUNDER TIP **Founder Tip: the call-back rule**

Never use the phone number, link or reply address supplied in the suspicious message. Use your own contact list, a previous email or the official website. A thirty-second call back has stopped more fraud than any filter.

Business email compromise: the expensive one

Many of the most expensive small-business incidents involve no malware at all. An attacker watches an email thread between you and a supplier, then sends a message from a look-alike address at exactly the right moment: *"Our bank details have changed, please pay this invoice to the new account."* The sums can be large and recovery is rare.

CONTROLS FOR PAYMENT REQUESTS

- ☐ Bank-detail changes are confirmed by phone with a known contact before payment.
- ☐ Payments above a set limit need two people to approve.
- ☐ Invoices are checked against orders or contracts, not just the amount.
- ☐ Staff who handle money have a way to flag a doubt without being told off.
- ☐ Look-alike domains of your business and key suppliers are monitored or blocked.

What to do if you clicked

Everyone clicks eventually. What matters is what happens in the next ten minutes. Make sure everyone knows the four steps before they need them.

1. Disconnect the device from the network if you entered a password or opened an attachment, and do not turn it off yet.
2. Tell your security contact immediately, by phone or in person. Do not wait to be sure.
3. Change the password for any account you typed it into, from a different, clean device, and sign out of all sessions.
4. Write down what happened: the time, the message, what you clicked and what you entered.

GOOD PRACTICE **Good practice: reward the report**

Thank the person who reports a suspicious email, even a harmless one. A culture where people report ten false alarms is far safer than one where nobody reports the one real attack. Share anonymised examples with the team each month.

DO THIS NOW **Do this now (15 minutes)**

Create a single mailbox or chat channel called "report-phishing" and tell your team. Put the call-back rule on a sticky note beside every phone that handles payments.

PART II · ACCESS AND ATTACK

CHAPTER

06

Remote Work, Devices and Shadow IT

The habits outside the office walls: personal phones, home Wi-Fi, free tools and the apps nobody told you about.

IN THIS CHAPTER

- Safe rules for personal devices and working from home
- What shadow IT is and why it appears
- How to handle public Wi-Fi, travel and shared spaces
- A simple approved-tools list that staff will actually use

Your team does not work only where your firewall is. They answer email on the train, edit a spreadsheet at the kitchen table, and message a client from a personal phone. Each of those places is a place where personal data can slip out. You cannot control the home, but you can control the **rules, the tools and the defaults**.

Personal devices: BYOD without the headache

"Bring your own device" is common in small businesses because it saves money. It also puts business data on equipment you do not manage. You do not have to ban it, but you do need to decide, in writing, what is allowed.

RISKY: UNWRITTEN BYOD

- Customer email is set up on any phone, with or without a passcode.
- Files are saved locally "to work offline".
- Nobody knows which devices hold business data.
- A lost phone means a guess about what was on it.

BETTER: SIMPLE, WRITTEN BYOD

- Only approved apps access business data, with a passcode and encryption enforced.
- Files stay in the cloud drive, not on the device.
- A short device register lists who uses what.
- A lost phone can be wiped of business data remotely.

Figure 18 Two approaches to personal phones and laptops

WATCH OUT **Respect your staff's privacy too**

If you can wipe or monitor a personal device, say so clearly in your policy, limit it to business data and apps where you can, and keep to what is proportionate. Employers have their own GDPR duties towards staff, covered in Chapter 7.

Working from home

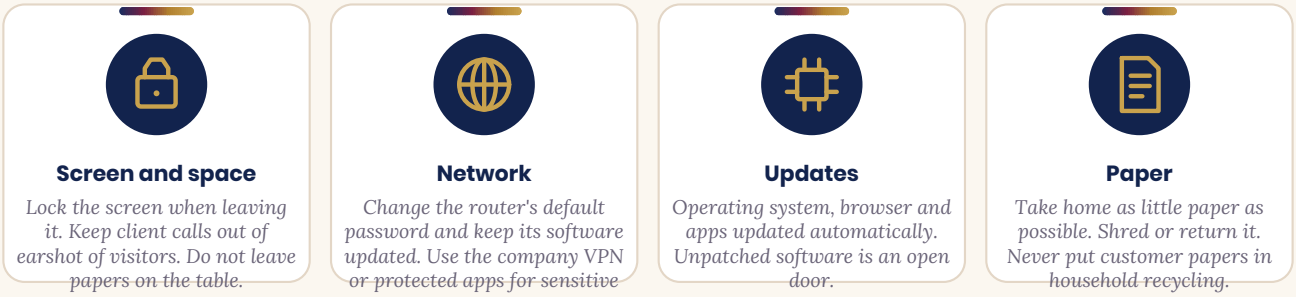


Figure 19 Four things to get right

Public Wi-Fi, travel and shared spaces

Cafes, airports and co-working spaces add risks that do not exist in the office: shoulder-surfing, fake hotspots and lost bags. The simple rules cover most of it.

OUT-OF-OFFICE RULES

- [ ] Use your phone's hotspot, or a trusted VPN, instead of unknown Wi-Fi for sensitive work.
- [ ] Use a privacy screen on laptops when working in public.
- [ ] Never leave a laptop or phone unattended, even for a minute.
- [ ] Do not discuss clients, customers or staff by name where others can hear.
- [ ] Do not photograph screens or whiteboards containing personal data.
- [ ] Report a lost device immediately, before searching for it.

Shadow IT: the tools nobody approved

Shadow IT is any app, service or tool staff use for work without the business knowing. It is rarely rebellion. A colleague finds a free scheduling tool, a PDF converter, a personal cloud drive or an AI note-taker because the official option is slower or does not exist. The data goes with them.

THE OFFICIAL TOOL IS TOO SLOW
If sharing a file through the approved route takes ten steps, someone will use a quicker one.

NOBODY ASKED
Staff often do not know there is a rule, who to ask, or that asking is welcome.

THE TOOL IS FREE
Free services are paid for with data. Terms of use may allow things you would never agree to.

IT FEELS HARMLESS
Pasting a "just a short list" or uploading "just one contract" does not feel like a data transfer.

Figure 20 Why shadow IT happens

An approved-tools list

The fix is not a ban. It is an **approved-tools list**: a one-page document naming the tools for email, files, chat, video calls, payments, notes, design and AI, and what data each is allowed to hold. Add a simple way to request something new, and a promise to answer within a week.

Approved-tools list: example

Purpose	Approved tool	Allowed data	Not allowed
Email and calendar	[Business email]	All business data	Forwarding to personal accounts
File storage	[Business cloud drive]	All business data, named sharing	"Anyone with link" for personal data
Team chat	[Business chat app]	Work discussion	Health data, ID documents, passwords
Video calls	[Business video tool]	Meetings, no recordings without notice	Personal accounts
AI assistant	[Approved AI tool, business plan]	Non-personal text, public information	Customer data, contracts, staff records
Payments	[Payment provider]	Payment links only	Card numbers in chat or email

FOUNDER TIP **Founder Tip: say yes to a safe version**

When a team member asks for a tool you cannot approve, offer the closest safe alternative the same week. People bypass rules when the safe route is slower than the risky one, and not otherwise.

Supplier and freelancer access

Contractors and freelancers are staff for risk purposes, whatever their contract says. Give them accounts of their own, limited to the project, with an end date. Use a written agreement that covers confidentiality, security and what happens to the data when the work ends. If they process personal data on your behalf, a data processing agreement is required under Article 28.

CONTRACTOR ONBOARDING

- [ ] Written agreement including confidentiality and data protection terms.
- [ ] Own account with the minimum access and an end date.
- [ ] Same staff rules and training as employees, before they touch personal data.
- [ ] Work done on the business tools, not on their own unmanaged ones, wherever possible.
- [ ] Access removed and data returned or deleted at the end, confirmed in writing.

DO THIS NOW **Do this now (30 minutes)**

Ask your team a friendly question in the next meeting: "*Which apps or tools do you use for work that I might not know about*?" Promise no blame. Add the answers to a list, decide which to approve, and replace the rest.

PART III · BUILDING THE CULTURE

CHAPTER

07

Staff Privacy Training That Works

How to turn a once-a-year slideshow into habits that stick, without boring or scaring anyone.

IN THIS CHAPTER

- What staff really need to know, by role
- How often to train and in what formats
- How to run phishing simulations fairly and lawfully
- How to measure whether the training is working

Most training fails for the same reason: it tries to teach everything once. A two-hour session in January is forgotten by February. Research on how people learn, and plain experience, point the same way: **short, frequent, practical and tied to real work** beats long, rare and theoretical.

What staff need to know

Keep the core message small. A new colleague should be able to answer five questions after their first week, and repeat the answers after a year.

WHAT IS PERSONAL DATA?
Anything that identifies a person: names, emails, photos, IDs, orders, notes. When unsure, treat it as personal.

WHERE MAY IT GO?
Only into approved tools and only to people who need it. Never into personal accounts or public AI tools.

HOW DO I SPOT TROUBLE?
Pressure, secrecy, odd requests, wrong sender. Pause, verify through a second channel.

WHAT IF I MAKE A MISTAKE?
Report immediately to the named contact. You will be thanked, not blamed.

WHO DO I ASK?
A named person with a phone number or chat handle, available and friendly.

Figure 21 The five core messages

Train by role

Not everyone needs the same depth. A tiered approach respects people's time and focuses on the risk they actually carry.

Training by role

Role	Needs most	Examples
Everyone	The five core messages, phishing basics, reporting	Short onboarding session, monthly reminders
Customer-facing	Verification of identity, handling requests, clean-desk habits	Support, sales, reception
Finance and payments	Payment fraud, call-back rule, dual approval	Accounts, bookkeeping
Managers	Access reviews, leaver routine, incident response	Team leads, owners
Admins and IT	Technical controls, logs, backups, patching	Whoever looks after systems
Freelancers	Same core messages, before access	Contractors, agency staff

The rhythm: little and often

Stage 1 — **Day one**
Thirty-minute induction before any access to personal data. Sign the staff rules.

Stage 2 — **Month one**
Short follow-up on phishing and reporting. Check understanding with a quick quiz.

Stage 3 — **Every quarter**
A ten-minute topic in the team meeting, based on a real or anonymised example.

Stage 4 — **Every year**
A refresher for everyone, an update on rule changes, and a review of the training log.

Figure 22 A training year for a small team

FOUNDER TIP **Founder Tip: use real examples**

A story from your own sector or from the news sticks better than a definition. After any near miss, share an anonymised version with the team in the next meeting. Ten minutes of "here is what happened and what we changed" is worth an hour of slides.

Formats that work



Figure 23 Mix the formats

Phishing simulations: handle with care

A **phishing simulation** sends staff a fake phishing email and records who clicks. Done well, it teaches and measures. Done badly, it humiliates people, breeds resentment and can raise legal issues. Employees are data subjects too, and the results are personal data about them.

RISKY: THE TRAP

- Staff are not told simulations exist.
- Individual results are shared with managers or at meetings.
- Fake emails promise bonuses or exploit fear of redundancy.
- Clicking leads to blame or disciplinary action.

BETTER: THE PRACTICE DRILL

- Staff are told in the policy that simulations happen, and why.
- Results are reported by team or in aggregate, not by name.
- Scenarios mimic real attacks without cruel or manipulative bait.
- A click leads to a friendly, instant tip, not a reprimand.

Figure 24 Running simulations

WHAT GDPR REQUIRES **What GDPR requires**

Using staff data for simulations needs a lawful basis, transparency and proportionality (Articles 5, 6, 12 and 13). Tell staff in your employee privacy notice, keep only what you need (aggregate rather than individual results where possible) and keep the data for a limited time. In some countries, works councils or employee representatives must be consulted about monitoring tools. Check local law before you start.

Measure what matters

Click rates alone are a poor measure. What you want is **behaviour change**: faster reporting, fewer repeat mistakes, fewer shared passwords, fewer open links. Track a handful of simple numbers once a quarter.



Figure 25 Four training signals to track (example monthly values)

Keep a training record

A simple log (name, date, topic, format) is evidence that you took training seriously. Keep it light: the aim is to show a pattern, not to build a file on each person. A template appears in the Bonus section.

GOOD PRACTICE **Good practice: make it a habit, not an event**

Put one line about data protection in every monthly team meeting. Recognise good catches in public. Make reporting the easiest thing to do: one shared mailbox, one chat channel, one phone number.

DO THIS NOW **Do this now (30 minutes)**

Write the five core messages on one page and read them aloud at your next meeting. Ask: "Which of these is hardest to follow in real life?" The answers show where to focus next.

PART III · BUILDING THE CULTURE

CHAPTER

08

Policies Your Team Will Actually Follow

Short rules, clear examples and fair consequences, in place of a forty-page document nobody opens.

IN THIS CHAPTER

- Why most security policies are ignored
- The one-page Staff Data Protection Rules
- Confidentiality clauses, acceptable use and fair consequences
- How to handle monitoring without breaking trust or the law

A policy that nobody reads protects nobody. Many small businesses either have no written rules at all, or a long document copied from a template that staff signed on day one and never saw again. Neither would help a regulator, an insurer or a new colleague on a busy Tuesday.

What makes a rule followable



Figure 26 Four tests for any rule

The one-page rules

Start with a single page of **ten rules**, based on the risks in this book. Read it aloud at induction, display it where people work, and revisit it twice a year. The Bonus section contains a ready-to-adapt version. A summary of what it should cover:

1. Use only approved tools for work, and ask before using a new one.
2. Never put personal data into personal accounts or public AI tools.
3. Use your own login and MFA. Never share passwords.
4. Lock your screen and keep devices encrypted and updated.
5. Share files with named people, not open links.
6. Verify any request for money, access or data through a second channel.
7. Report mistakes and suspicious messages at once, to the named contact.
8. Take only the data you need, and delete what you no longer need.
9. Keep paper locked away and shred it when finished.
10. When you leave or change role, return everything and your access ends.

Contracts and confidentiality

Employment contracts and freelancer agreements should include a **confidentiality clause** that continues after the work ends, a reference to the staff data protection rules, and a note that deliberately misusing personal data may lead to disciplinary action. Under Article 28 and 29 of the GDPR, those working for you must act only on your instructions, so a written instruction is also a legal safeguard.

WATCH OUT **Not a substitute for advice**

Confidentiality, disciplinary and monitoring rules vary between countries. Have an employment lawyer or local expert review your contract wording and any policy that affects staff rights.

Fair consequences

People take rules seriously when they are applied fairly. Distinguish three situations in advance, and tell staff the difference.

A fair response to different situations

Situation	Typical example	Response
Honest mistake	Wrong attachment, clicked a link	Support, quick fix, learning. No blame.
Careless or repeated breach	Sharing passwords after a warning, ignoring the rules	Coaching, written reminder, retraining.
Deliberate misuse	Copying customer lists to a competitor, snooping on a friend	Disciplinary process, legal advice, possible report to authorities.

Monitoring staff: handle with care

It can be tempting to answer human risk with surveillance: logging keystrokes, reading messages, tracking locations. Employees have privacy rights, and the GDPR applies to the data you collect about them. Heavy-handed monitoring can be unlawful, damages trust and is often less effective than good access control. If you do need some monitoring for security, keep it targeted and open.

BEFORE MONITORING STAFF

- [ ] You have a clear, specific purpose, such as protecting systems or investigating a serious incident.
- [ ] You considered less intrusive options and chose the minimum needed.
- [ ] You told staff in advance what is monitored, why, and for how long data is kept.
- [ ] You limited access to monitoring data to a few named people.
- [ ] You checked national employment and data protection rules, and any rules on consulting employee representatives.
- [ ] You considered whether a data protection impact assessment is needed for large-scale or systematic monitoring.

WHAT GDPR REQUIRES **What GDPR requires**

Staff are data subjects. They have the right to be informed (Articles 13 and 14), and monitoring must be lawful, fair, transparent and proportionate (Article 5). Article 88 allows Member States to set more specific rules for employment, so national law may add requirements.

Make the rules visible

GOOD PRACTICE **Good practice: a poster and a promise**

Print the ten rules on one page. Put it on the wall by the printer and at the top of the shared drive. Add one line at the bottom: "If you make a mistake, tell [name] straight away. We will fix it together." That sentence does more for security than most software.

DO THIS NOW **Do this now (45 minutes)**

Copy the Staff Data Protection Rules from the Bonus section. Change the brackets, remove anything that does not apply, and read it to a colleague. Where they hesitate or ask "what do you mean by that?", rewrite the sentence in plainer words.

PART IV · WHEN IT GOES WRONG, AND WHAT NEXT

CHAPTER

09

When It Goes Wrong

The first hours after a mistake or a phishing success, and a simple plan for handling them calmly.

IN THIS CHAPTER

- The five steps of a small-business incident response
- What to do in the first hour
- How the 72-hour clock works in practice
- How to learn from an incident without blaming anyone

Sooner or later something will go wrong. The difference between a bad week and a disaster is not luck: it is whether people knew what to do in the first hour. A short, rehearsed plan beats a detailed, unread one.

The five steps

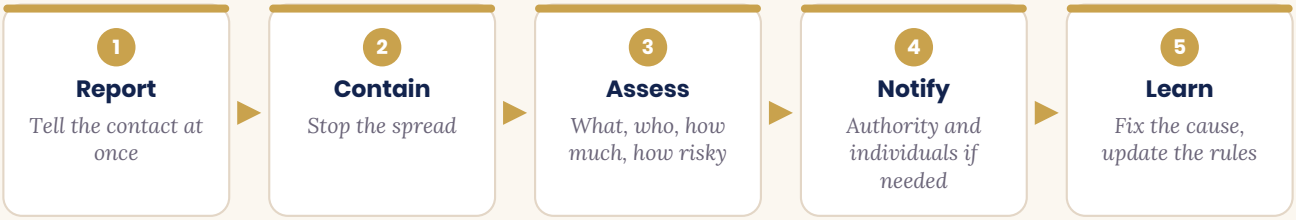


Figure 27 Incident response in five steps

The first hour

1. Stop and tell: the person who noticed reports to the named incident contact immediately, by phone if possible.
2. Contain: disconnect the affected device from the network, disable the compromised account, recall the email if the tool allows, remove public links.
3. Preserve: write down times, screenshots and messages. Do not delete evidence or restart systems unless advised.
4. Assign: one person leads and keeps a timeline. Others do tasks, not opinions.
5. Decide: is this a personal data breach? If yes, the 72-hour clock has started from the moment you became aware.

WHAT GDPR REQUIRES **What GDPR requires**

You must notify the supervisory authority **without undue delay and, where feasible, not later than 72 hours after becoming aware** of a breach, unless it is unlikely to result in a risk to people (Article 33(1)). If you cannot provide everything at once, you may give information in phases (Article 33(4)). The notification must describe the nature of the breach, categories and approximate numbers of people and records, the likely consequences, the contact point and the measures taken. A processor must tell the controller without undue delay (Article 33(2)).

Assess the risk

Risk is about the **people affected**, not the business. A leaked email list with names is different from a leaked spreadsheet with medical details. Use a simple scoring approach, and record your reasoning in the breach log, whatever the outcome.

A simple breach risk guide

Factor	Lower risk	Higher risk
Type of data	Business contact details	Health, financial, ID, passwords, children
Volume	A handful of people	Hundreds or thousands
Recipient	A known, trusted person	Unknown, public or hostile
Protection	Encrypted or password-protected	Plain text
Recoverability	Retrieved or deleted, confirmed	Out of your control

Telling the people affected

When a breach is likely to result in a **high risk** to individuals, you must tell them without undue delay (Article 34). Use clear, plain language: what happened, what data, what you are doing, what they can do to protect themselves, and whom to contact. Do not hide behind jargon, and do not delay in order to get the wording perfect.

> FOUNDER TIP **Founder Tip: write the template before you need it**
>
> Draft a half-page notification message now, with blanks for date, data and contact. In a real incident you will be under pressure, and a template turns a hard hour into a fill-in-the-blanks task.

Keep a breach log

Article 33(5) requires you to document **every** personal data breach, including those you do not report: the facts, the effects and the remedial action. A simple table is enough. It also protects you: a record of a sensible decision not to notify is far better than no record at all.

Learn without blaming

A good review asks four questions: What happened? Why was it possible? What worked? What will we change? The answer to "why was it possible?" is almost never a single person. It is usually a missing control, an unclear rule or too much access.

BEFORE & AFTER **After a wrong-recipient email**

RISKY	*Remind everyone to be more careful and move on.*
BETTER	*Ask the recipient to delete it and confirm, log the breach, and brief the team on what happened.*
BEST PRACTICE	*Do all of the above, then switch on external-recipient warnings and a send delay, reduce what the team attaches to emails, and review the use of mailing tools for group messages.*
WHY IT MATTERS	Telling people to be careful does not change the conditions that caused the mistake. Changing the system does.

Practise before it happens

Once a year, run a **tabletop exercise**. Gather the team for thirty minutes, describe an incident ("A colleague just told you they replied to a fake invoice email and sent payment"), and ask each person what they would do first. You will find gaps in minutes: nobody knows the incident contact, the phone list is out of date, the cloud admin is on holiday.

INCIDENT READINESS

- [ ] A named incident contact and a backup, with phone numbers everyone has.
- [ ] One page describing the five steps, on the wall and in the shared drive.
- [ ] A breach log template, ready to fill.
- [ ] A draft notification template for individuals.
- [ ] The supervisory authority's reporting page bookmarked.
- [ ] Cyber insurance details, including the emergency number, easy to find.
- [ ] A tabletop exercise held in the last 12 months.

DO THIS NOW **Do this now (30 minutes)**

Write the name and number of your incident contact on a card and put it by every desk. Bookmark your national data protection authority's breach-reporting page. These two actions save hours when you most need them.

PART IV · WHEN IT GOES WRONG, AND WHAT NEXT

CHAPTER

10

Your 90-Day Human Risk Plan

Three phases, a few hours a week, from "we hope for the best" to a team that handles data safely.

IN THIS CHAPTER

- A realistic 90-day plan that fits a busy small business
- A ten-point self-check of your human risk
- The monthly rhythm that keeps the gains
- When to call a professional

You have now seen the whole picture. The temptation is to try to fix everything this week. Resist it. A modest plan that is **finished** protects you more than an ambitious plan that is abandoned in February. The plan below takes about two to three hours a week for thirteen weeks. Start with access and reporting, because they pay back fastest.

Where do you stand?

Give yourself one point for each statement that is true today. Be honest: "not sure" scores zero.

THE HUMAN RISK SELF-CHECK

- ☐ Every person has their own login for each business tool.
- ☐ Multi-factor authentication is on for email, finance and customer data.
- ☐ When someone leaves, their access ends on their last day.
- ☐ Staff know exactly who to tell if they make a mistake.
- ☐ There is a written one-page set of staff data protection rules.
- ☐ New starters are trained before they access personal data.
- ☐ Bank-detail changes and urgent payments are verified by a second channel.
- ☐ Shared drives are not set to "anyone with the link" for personal data.
- ☐ Business devices are encrypted, locked and can be wiped remotely.
- ☐ We have recorded every incident of the last year, even small ones.

0 to 3	4 to 6	7 to 8	9 to 10
Exposed	**Getting There**	**Resilient**	**Well Protected**
The basics are missing. Start with phase 1 now, and begin with MFA and the leaver routine.	Good instincts and some gaps. Close the gaps where you scored zero and write the rules down.	A solid base. Focus on training rhythm, evidence and incident practice.	You manage the human side well. Keep reviewing and keep the culture alive.

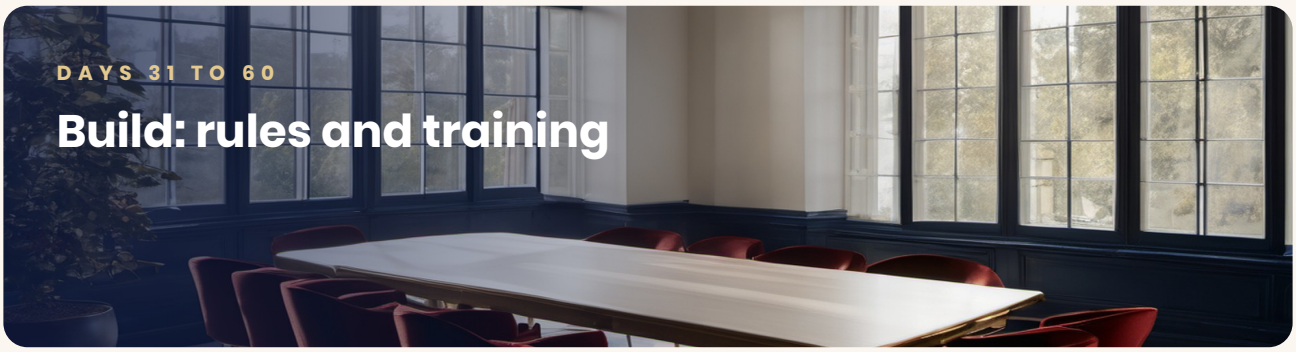
Figure 28 Your Human Risk score



DAYS 1 TO 30

Foundation: access and reporting

DAY 1	**Name an incident contact and a backup** Put their numbers where everyone can see them	☐ DONE
DAY 3	**Switch on MFA for email and finance** Admin accounts first, then everyone	☐ DONE
DAY 7	**List every tool the team uses** Include free and personal ones	☐ DONE
DAY 10	**Export user lists and remove leavers** Start with email, shop and cloud drive	☐ DONE
DAY 14	**Fix risky sharing** Replace "anyone with the link" on sensitive folders	☐ DONE



DAYS 31 TO 60

Build: rules and training

DAY 31	**Write the one-page staff rules** Use the Bonus template and read it aloud	☐ DONE
DAY 35	**Run a 30-minute training session** Five core messages and the reporting routine	☐ DONE
DAY 40	**Create the approved-tools list** Say yes to a safe alternative for each need	☐ DONE
DAY 45	**Set up the call-back rule for payments** Two approvals above your limit	☐ DONE
DAY 50	**Draft the incident and breach templates** Use the forms in the Bonus	☐ DONE



DAYS 61 TO 90

Prove: practise and review

DAY 61	**Hold a tabletop incident exercise** Thirty minutes with the whole team	☐ DONE
DAY 66	**Send a first phishing drill, or a spot-the-phish quiz** Aggregate results, friendly feedback	☐ DONE
DAY 72	**Complete the first quarterly access review** Record the date and changes	☐ DONE
DAY 80	**Update contracts and onboarding packs** Add confidentiality and the rules	☐ DONE
DAY 90	**Review the plan and set next quarter's goals** Re-score the self-check	☐ DONE

Keeping it alive

MONTHLY
One data protection topic in the team meeting. Review reports of suspicious emails. Check that leavers' access was removed.

QUARTERLY
Access review. Short training topic. Check the approved-tools list and shared links.

ANNUALLY
Refresh training for everyone. Tabletop exercise. Review rules, contracts and the breach log. Re-score the self-check.

Figure 29 The rhythm that makes it stick

FOUNDER TIP **Founder Tip: start small, finish first**

A finished fix for one risk beats a perfect plan for ten. If the 90 days feel heavy, do only the first 30 and repeat. Momentum matters more than completeness.

THE COMPOUNDING RULE

You do not need a perfect team. You need a team that gets a little safer every month.

Remove one unneeded access this week. Add one reminder next week. Thank one person for reporting something. In a year you will have made fifty small improvements, and your business will be harder to attack, easier to run and calmer when the unexpected happens.

When to ask a professional

Take advice from a qualified lawyer, data protection professional or security specialist if you hold health or other sensitive data at scale, if you suspect a serious breach or insider wrongdoing, if you plan staff monitoring, if an authority or a customer contacts you, or if your contracts and insurance impose specific requirements. Knowing when to ask is part of running a responsible business.

BONUS

K

The Staff Protection Toolkit

A one-page staff rules template, access matrix, incident report form, breach log, training log and review checklist. Fill in the brackets and the blank fields.

IN THIS CHAPTER

- Ten Staff Data Protection Rules you can adapt in an hour
- A fillable access matrix and quarterly review
- An incident report form and a breach log
- A training log and a joiner, mover and leaver checklist

WATCH OUT **How to use this toolkit**

These are **educational templates, not legal advice**. Replace every [bracket] with your own details, delete what does not apply and add what is missing. Have the final versions checked against the employment and data protection rules of your country. The PDF fields can be filled in on screen or printed.

Staff Data Protection Rules

[Business name] · Version [1.0] · Date [DD Month YYYY] · Owner [Name and role] · Next review [DD Month YYYY]

Why these rules exist

We look after information about our customers, colleagues and partners. They trust us with it, and the law requires us to protect it. These rules apply to everyone who works for us: employees, freelancers, interns and agency staff. They are short on purpose. If anything is unclear, ask [Name] before you act.

The ten rules

- **1. Approved tools only.** Use only the tools on our approved list for work. Ask [Name] before using anything new, including free apps and AI tools.
- **2. Keep personal data in the right places.** Never put customer or staff data into personal email, personal cloud storage, messaging apps or public AI tools.
- **3. Your login is yours.** Use your own account and multi-factor authentication. Never share or write down passwords. Use the company password manager.
- **4. Protect your device.** Keep devices locked, encrypted and updated. Lock the screen whenever you step away.
- **5. Share with care.** Share files with named people, not open links. Check the recipient before pressing send, and use BCC or a mailing tool for groups.
- **6. Stop and verify.** For any request involving money, bank details, passwords or personal data, confirm by phone using a number you already have.
- **7. Report at once.** If you make a mistake, lose a device or see something suspicious, tell [Name, phone] immediately. You will be thanked, not blamed.
- **8. Take only what you need.** Collect, copy and keep only the data you need for the task. Delete or return what you no longer need.
- **9. Paper and screens.** Lock away paper with personal data, shred it when finished, and keep screens out of sight in public places.
- **10. Moving on.** When you leave or change role, return all devices and data. Your access ends on your last day, and confidentiality continues afterwards.

What happens if rules are broken

Honest mistakes reported quickly are treated as learning opportunities. Repeated or careless breaches lead to coaching and retraining. Deliberate misuse of personal data may lead to disciplinary action and, where the law requires, a report to the authorities.

Acknowledgement

WORKSHEET

Staff acknowledgement

Sign once at induction and again after any major change.

Name and role

Date

I have read and understood the Staff Data Protection Rules

Signature

Access matrix

List your roles and tools. Fill each cell with the minimum access needed: None, Read, Edit, Admin. Review every quarter.

ACCESS MATRIX

Role or person	Email	Cloud drive	Shop or CRM	Finance	HR files	Marketing	Admin rights	Review date
e.g. Customer support	*Own mailbox*	*Support folder*	*Read orders*	*None*	*None*	*None*	*No*	2026-04-01

Joiner, mover and leaver checklist

JOINER

- [ ] Role confirmed and access granted by role, not by request.
- [ ] Own accounts created, MFA switched on.
- [ ] Rules read, acknowledgement signed, induction training done before personal data access.
- [ ] Device issued, encrypted, and recorded in the device register.

MOVER

- [ ] Old access reviewed and removed at the moment the new access is added.
- [ ] Training refreshed for the new role.
- [ ] Access matrix updated.

LEAVER

- [ ] Last day and handover confirmed with the manager.
- [ ] All accounts, sessions and tokens disabled on the last day.
- [ ] Devices, keys, badges and paper files returned.
- [ ] Shared passwords changed, and the person removed from shared mailboxes and groups.
- [ ] Mailbox forwarded or archived according to policy, then closed.
- [ ] Reminder of continuing confidentiality given.
- [ ] Access check repeated one week later.

Incident report form

WORKSHEET

Incident report

Anyone can complete this. Send it to [Name, contact] as soon as you notice a problem. A phone call comes first if it is urgent.

Date and time you noticed

Your name and role

What happened (facts only)

What data or systems were involved

Who might be affected, and roughly how many

What did you do straight away

Anything you are unsure about

Breach log

Record every personal data breach, even those you decide not to report to the authority (Article 33(5)).

BREACH LOG

Date and time	What happened	Data and people affected	Risk level	Reported to authority?	Individuals told?	Actions taken	Lessons and changes
e.g. 2026-05-04 09:10	*Email with customer list sent to wrong recipient*	*120 customers, names and emails*	*Low*	*No, reasoning recorded*	*No*	*Recipient confirmed deletion*	*Send delay switched on*

Training log

TRAINING LOG

Date	Person or group	Topic	Format	Trainer	Notes or follow-up
e.g. 2026-02-10	*All staff*	*Phishing and reporting*	*30-minute live session*	*A. Smith*	*Quiz average 90%*

Quarterly access review

WORKSHEET

Quarterly Access Review

Complete once a quarter and file it with the access matrix.

Date of review and who attended

Systems reviewed

People removed or changed

Accounts unused for 90 days

External shares removed

Actions agreed, owners and deadlines

Notification message to individuals: template

Subject: Important information about your personal data. Dear [Name], we are writing to tell you about an incident that affected some of the information we hold about you. On [date] [what happened, in one or two plain sentences]. The information involved was [list of data]. We have [what you have done to contain it]. We recommend that you [specific steps, such as changing passwords or watching for suspicious messages]. If you have questions, please contact [Name] at [phone and email]. We are sorry this happened, and we will keep you informed.

ANNUAL REVIEW CHECKLIST

- [ ] The staff rules were re-read by everyone and re-signed.
- [ ] The access matrix matches real roles and tools.
- [ ] Leavers in the last year were handled correctly.

- [ ] MFA covers every account that holds personal data.
- [ ] A tabletop exercise was held.
- [ ] The breach log and training log are up to date.
- [ ] Contracts and onboarding packs contain the latest wording.

AI & PRIVACY **Where to go next**

Free tools, a privacy notice generator and updates on staff data protection guidance are available at **gdprgard.eu**.

Plain-English Glossary

The security and privacy vocabulary used in this book.

Access control	Rules and technology that decide who can see or change which data.
Accountability	The duty to comply with the GDPR principles and to be able to show that you do (Art. 5(2)).
Business email compromise	A scam in which an attacker impersonates or hijacks a trusted email account to request payments or data.
Controller	The person or business that decides why and how personal data is processed.
Encryption	Scrambling data so that only someone with the key can read it.
Insider risk	Risk from people who already have legitimate access, whether by accident, deception or intent.
Joiner, mover, leaver	The three moments, starting, changing role and leaving, at which access must be set up, adjusted or removed.
Least privilege	Giving each person only the access they need to do their job.
Multi-factor authentication (MFA)	Logging in with two or more proofs, such as a password and a code from an app or a security key.
Password manager	A tool that creates, stores and fills in long, unique passwords.
Personal data	Any information relating to an identified or identifiable living person (Art. 4(1)).
Personal data breach	A security incident leading to accidental or unlawful destruction, loss, alteration, disclosure of or access to personal data (Art. 4(12)).

Phishing	A message, usually email, that pretends to be someone trustworthy to trick you into clicking, paying or sharing credentials.
Pretexting	Inventing a believable story to extract information from a target step by step.
Processor	A person or business that processes personal data on behalf of a controller.
Shadow IT	Apps and services used for work without the business knowing or approving them.
Smishing	Phishing by text message or chat.
Social engineering	Manipulating people, rather than systems, to gain access or information.
Spear phishing	A phishing attack tailored to a specific person or business.
Tabletop exercise	A talk-through of an imagined incident to test who does what.
Vishing	Phishing by phone call or voice message.

Official Sources & Further Reading

Where the claims in this book come from, and where to check what applies today.

Always prefer the primary sources below to summaries, including this one. Web addresses change: if a link has moved, search the official site for the title shown. Guidance is updated regularly, so check for the latest version before relying on it.

Primary EU law (EUR-Lex)

- **General Data Protection Regulation (GDPR)**, Regulation (EU) 2016/679. Notably Art. 4(12) (personal data breach), Art. 5(1)(f) and 5(2) (integrity and confidentiality, accountability), Arts. 12 to 14 (transparency, including to staff), Art. 24 (controller responsibility), Art. 25 (data protection by design and by default), Art. 28 and 29 (processors and persons acting under authority), Art. 32 (security, including 32(4)), Arts. 33 and 34 (breach notification), Art. 39(1)(b) (awareness-raising and training), Art. 82 (compensation), Art. 83 (fines) and Art. 88 (employment). eur-lex.europa.eu/eli/reg/2016/679/oj
- **NIS2 Directive**, Directive (EU) 2022/2555, on measures for a high common level of cybersecurity. Check whether your sector and size bring you into scope in your Member State. eur-lex.europa.eu/eli/dir/2022/2555/oj

Regulators and guidance

- **European Data Protection Board (EDPB)**, Guidelines 9/2022 on personal data breach notification under the GDPR, including examples of breaches caused by human error and phishing: edpb.europa.eu
- **Information Commissioner's Office (UK)**, guidance on personal data breaches and security: ico.org.uk
- **ENISA**, the EU Agency for Cybersecurity, guidance on cyber hygiene and the annual Threat Landscape report: enisa.europa.eu
- **National Cyber Security Centre (UK)**, small business guide and staff training material: ncsc.gov.uk
- **Your national data protection authority**, for breach reporting forms, national employment rules and monitoring limits. Find yours on the EDPB website.

Industry reports and public incident accounts

- **Verizon, Data Breach Investigations Report 2025**: the human element involved in about 60% of breaches in 2024, and findings on credential abuse and social engineering. verizon.com/business/resources/reports/dbir
- **IBM, Cost of a Data Breach Report 2025**: global average cost of USD 4.44 million, and phishing as the most common initial vector. ibm.com/reports/data-breach
- **Twitter, "An update on our security incident" (July 2020)**: description of the phone spear-phishing attack against employees. blog.twitter.com archive
- **Uber, security update (September 2022)**: description of the contractor account compromise and MFA prompt attack. uber.com/newsroom

> WATCH OUT **What this book could not verify for you**
>
> Industry statistics are reproduced as published and change every year. Descriptions of the Twitter and Uber incidents are summarised from the companies' own public statements and may have developed since. Time limits, employment-law rules, monitoring rules and fine ranges differ between countries and change over time. Check each against the primary source, and take advice from a qualified professional before relying on them.

About the Author

Zirlandia Milkovic

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that

founders should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy founders can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Stay in touch

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other businesses find it.

> AI & PRIVACY **Note to the reader**
>
> This book is educational and not legal advice. Laws and guidance change, so check the sources in the previous section and consult a qualified professional about your own circumstances.


Clear rules.
Careful access.
A team that speaks up.
ZIRLANDIA MILKOVIC